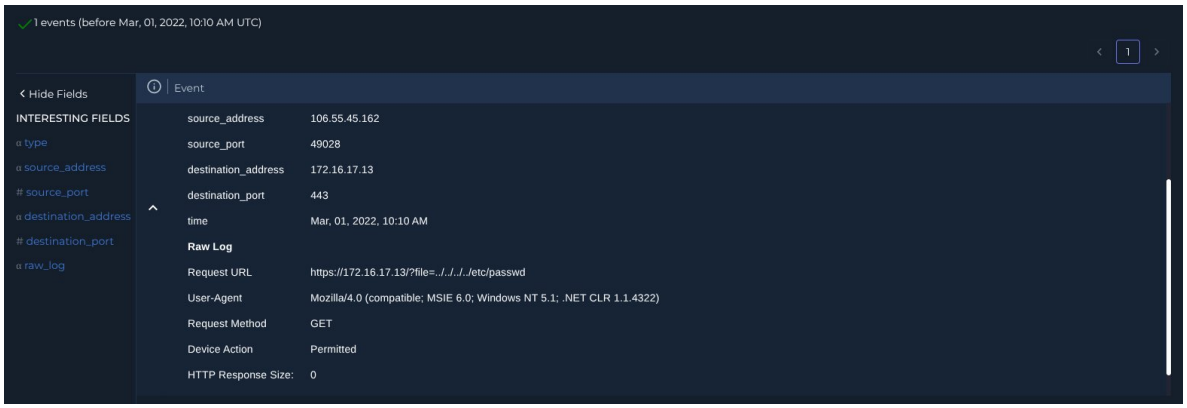
Event Information:

High	Mar, 01, 2022, 10:10 AM	SOC170 - Passwd Found in Requested URL - Possible LFI Attack	120	Web Attack

EventID :	120
Event Time :	Mar, 01, 2022, 10:10 AM
Rule :	SOC170 - Passwd Found in Requested URL - Possible LFI Attack
Level :	Security Analyst
Hostname :	WebServer1006
Destination IP Address :	172.16.17.13
Source IP Address :	106.55.45.162
HTTP Request Method :	GET
Requested URL :	https://172.16.17.13/?file=../../../../etc/passwd
User-Agent :	Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1; .NET CLR 1.1.4322)
Alert Trigger Reason :	URL Contains passwd
Device Action :	Allowed

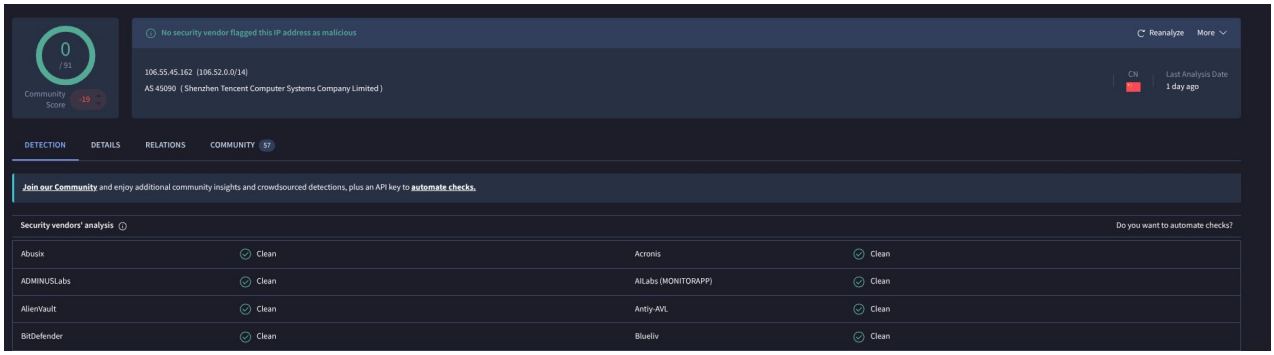
Analysis Steps:

Logs were searched with IP 106[.]55.45.162 in the relevant time-frame yielding 1 event. We can see the event that triggered the alert.

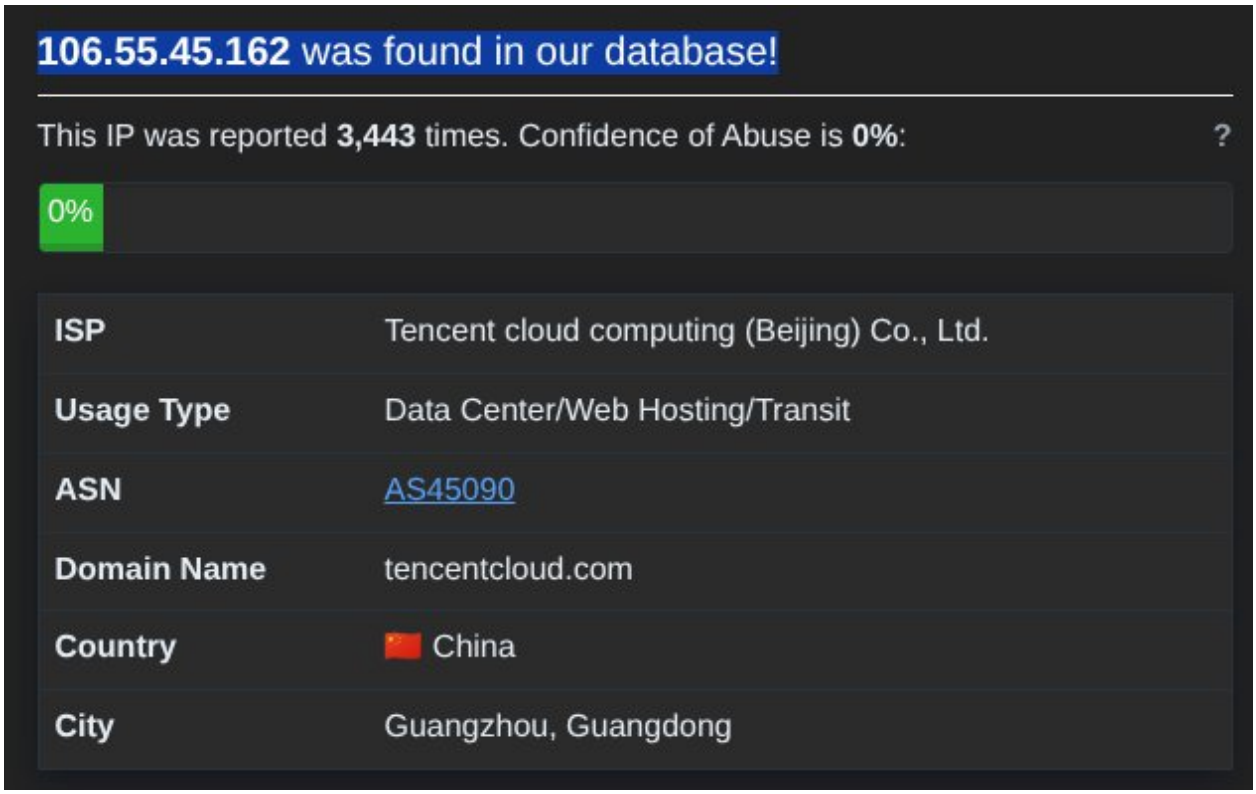


The response size was 0 and as such this was a failed True Positive.

The offending IP is not in our CTI database and is external to the organisation. No emails have been received indicating penetration testing involving the IP for the relevant time period. VirusTotal indicates it is a Chinese address associated with 106[.]55.45.162 AS 45090 (Shenzhen Tencent Computer Systems Company Limited). 0/91 security vendors flagged this IP address as malicious as of 1 day ago.



On AbuseIPDB this IP was reported 3,443 times with a 0% confidence of abuse.



Based on following Playbook procedure and the analysis of available information, this alert is determined to be a failed True Positive.

Report:

Incident Summary

Analysis confirms a failed True Positive Local File Inclusion (LFI) attack attempt targeting WebServer1006. An external threat actor attempted to use directory traversal to access the sensitive /etc/passwd file. Although the network permitted the request, the HTTP response size of 0 indicates the attempt was unsuccessful, classifying this as a failed True Positive.

Incident Details

- **Alert Name:** SOC170 - Passwd Found in Requested URL - Possible LFI Attack
- **Attacker IP:** 106[.]55.45.162
- **Target Host:** WebServer1006 (172[.]16.17.13)
- **Request URL:** hxxps://172[.]16.17.13/?file=../../../../etc/passwd
- **Device Action:** Permitted

Analysis and Evidence

- **Attack Vector:** The attacker initiated a GET request to the web server, manipulating the ?file= parameter.
- **Payload Identification:** They utilised a directory traversal payload (../../../../etc/passwd) in a direct attempt to read the local system password file.
- **Execution Status:** Log analysis confirms the network perimeter permitted the request.
- **Failed Exploitation:** The HTTP Response Size was recorded as 0, leading to the conclusion that the file read was unsuccessful and the attack failed.
- **User Agent:** The web request was made using an outdated Internet Explorer 6 User-Agent (Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1; .NET CLR 1.1.4322)).

Threat Intelligence

- **Infrastructure OSINT:** The source IP 106[.]55.45.162 is assigned to Tencent Cloud (AS 45090) and is geographically located in China.
- **IP Reputation:** VirusTotal currently flags the IP with 0/91 malicious detections as of one day ago.
- **Historical Abuse:** AbuseIPDB lists 3,443 historical reports for this address, despite currently holding a 0% confidence of abuse score.
- **Internal Correlation:** The offending IP is external to the organisation and is not present in the internal CTI database.
- **Authorisation Check:** A review of internal communications confirmed no authorised Red Team penetration testing is scheduled involving this IP for the relevant time period.

Actions Taken

1. Searched proxy logs for the source IP to identify the specific web request and LFI payload.
2. Noted the "Permitted" device action and verified the HTTP response size was 0.
3. Confirmed through internal communications that no authorised testing was taking place.
4. Declared the alert a failed True Positive because the attack was a legitimate, hostile attempt but the 0-byte response indicates it did not succeed.

Let's Defend Result

